

信息安全测评 与风险评估

安全等级识别与实践操作

授课教师：张玉



目录

CONTENTS

- 01 复习与导入
- 02 知识讲解：等级识别方法
- 03 等级判定标准对比
- 04 等级对应的测评指标差异

知识回顾

 **标准体系：**1+N标准体系，核心为GB/T 22239-2019。

 **安全理念：**从被动防御转向主动防御、动态防御。

 **安全等级：**共分五级，第三级（安全标记保护级）和第二级（系统审计保护级）最常见。

思考与警示

- **场景对比：**
 - 乡镇政府网站：服务乡镇居民，以公开信息为主，影响范围有限。
 - 省级政务平台：服务全省，涉大量敏感数据，影响范围广、损失大。
- **核心思考：**它们应该分别定几级？为什么？
- **真实警示：**2023年某县级政务系统因定级不准，未按三级要求防护致数据泄露。



谈谈为什么说“定级是等保工作的第一步，也是最关键的一步”？

- 知识讲解：等级识别方法



1. 定级依据： GB/T 22240 《信息安全技术 信息系统安全等级保护定级指南》



2. 定级要素： 业务信息安全等级（S）+ 系统服务安全等级（A）



3. 定级流程： 确定定级对象 → 确定安全保护等级 → 专家评审 → 主管部门审批 → 公安机关备案



4. 等级取值： S1A2、S2A2、S3A3……取两者较高者



★ 关键口诀：“先定对象，再评S/A，取高者，专家审，报备案”

- 等级判定标准对比

等级	业务信息安全（S）	系统服务安全（A）	典型系统
二级	损害公民/法人权益	严重损害公民权益或损害社会秩序	县级政务、高校官网
三级	严重损害社会秩序/公共利益	严重损害社会秩序或损害国家安全	地市级政务、金融机构
四级	特别严重损害社会秩序/公共利益	特别严重损害社会秩序或严重损害国家安全	国家重要领域核心系统



互动提问

某大型国企ERP系统，存储全国客户数据，应定几级？（小组讨论）

- 等级对应的测评指标差异

■ **核心差异：等级越高，测评指标越多、要求越严格。**



对比示例（安全通信网络）

不同安全保护等级在“安全通信网络”控制点上的具体要求存在递进关系。



二级要求

网络架构需划分区域，采用**校验技术**保证数据完整性。



三级要求及关键对比

增加“通信线路、关键设备硬件冗余”“**密码技术**保证数据保密性”。

关键对比：三级要求“应采用密码技术保证通信过程中数据的保密性”，二级无此强制要求。

等级保护与国家安全

🔧 核心观点

网络安全等级保护制度是《网络安全法》确立的基本制度，是维护国家网络空间主权和安全利益的重要保障。

🔧 案例

某关键信息基础设施因未按规定定级、未落实三级防护要求，导致遭受境外APT攻击，造成重大损失。

🔧 启示

准确识别安全等级是落实等级保护的第一步，是每个测评工程师的基本职责。

- 课堂小结

知识回顾：

1. 定级三要素

定级对象、S级、A级

2. 定级原则

取高者

3. 等级差异

等级越高，测评指标越多，要求越严格

4. 实践技能

能使用平台查看项目信息，能识别等级差异

关键词：

定级

S/A

取高者

等级差异

对照表